

Compliance and audit: Config, Audit Manager, Security Hub CSPM and Artifact

Four services, four different questions – and one of them moved to maintenance mode in April 2026.

Artifact is evidence about AWS. Everything else is evidence about you.

Four services, four questions

SERVICE	ANSWERS
AWS Config	What is the configuration, and has it changed?
Security Hub CSPM	How does my posture score against a standard?
Audit Manager	Can I hand an auditor organised evidence?
AWS Artifact	Is AWS itself compliant?

ON THE EXAM

Config is the substrate. Security Hub CSPM and Audit Manager both consume it, and Artifact is unrelated to all three.

AWS Config

- ◆ The **configuration recorder** captures configuration items over time. No recorder, no data – the module 4 dependency.
- ◆ **Rules** evaluate current state against desired state – AWS managed, custom Lambda, or Guard.
- ◆ **Remediation** via SSM Automation. Config is the one service here that can fix things.
- ◆ **Aggregators** collect data across accounts and Regions into one view.
- ◆ **Advanced queries** are SQL over your config data; **GetResourceConfigHistory** gives a resource timeline.

ON THE EXAM

The resource timeline is the underrated feature: it answers 'what did this look like on the day of the incident'.

Conformance packs

- ◆ A **collection of Config rules and remediation actions** deployed as one unit, per account or org-wide.
- ◆ **Over 100 pre-defined templates** – PCI DSS, HIPAA, FedRAMP, NIST 800-53, CIS.
- ◆ The dashboard gives a **compliance score**, a timeline, and drill-down to individual resources.
- ◆ You can define your own templates, grouping rules with remediation actions.
- ◆ **No SOC 2 or GDPR template.** AWS names those as the most notable gaps.

ON THE EXAM

AWS now positions conformance packs as its compliance direction. The gaps matter.

The Audit Manager change, stated plainly

- ◆ **Audit Manager moved to maintenance mode. From 30 April 2026 it cannot be set up in new accounts.**
- ◆ Existing customers continue where it is already set up, **including creating new assessments.**
- ◆ But **no additional Regions, accounts or organisations**, and **no new features or frameworks.**
- ◆ AWS points to **Config conformance packs**, and says plainly they are **not a direct replacement.**
- ◆ Not a shutdown. Existing deployments keep working, and code fixes continue.

ON THE EXAM

Dated: this is the fourth service in this course that the exam guide may still name while AWS has stopped investing in it.

What Audit Manager did that Config does not

- ◆ **Four evidence sources:** service API calls, Security Hub controls, CloudTrail events, and Config rules. **Config records configuration items only.**
- ◆ **35 managed frameworks** including SOC 2 and GDPR, against over 100 conformance pack templates that omit both.
- ◆ **Audit reports exportable as PDF**, plus CSV from evidence finder. Config has no equivalent reporting feature.
- ◆ **Audit Manager could not remediate. Conformance packs can.** The trade runs both ways.
- ◆ AWS's own guidance for the remaining gap points at **partner solutions** alongside Config.

ON THE EXAM

A PCI DSS pack holds the technical controls a Config rule can evaluate. No rule checks that you wrote a policy.

Security Hub CSPM

- ◆ Enables **standards** – AWS FSBP, CIS, PCI DSS, NIST 800-53 – as service-linked Config rules.
- ◆ Produces a **security score** and per-control status, with severity ratings.
- ◆ **Central configuration** applies it across Regions, accounts and OUs from one place.
- ◆ **Limited frameworks.** No SOC 2, no HIPAA standard.
- ◆ **Consolidated control findings:** one finding per check, across all standards.

ON THE EXAM

Module 1: 'Security Hub CSPM' is what was Security Hub before the Dec 2025 split.

AWS Artifact

- ◆ On-demand access to **AWS's own compliance reports** – SOC 1, SOC 2, SOC 3, ISO certifications, PCI DSS attestations, FedRAMP packages.
- ◆ Also **agreements**, including the **Business Associate Addendum** for HIPAA workloads, which you accept in Artifact.
- ◆ Reports are usually covered by a **non-disclosure agreement**, so you accept terms before downloading.
- ◆ **It says nothing about your configuration.** An AWS SOC 2 report does not make your workload SOC 2 compliant.
- ◆ Third-party reports from ISVs in AWS Marketplace are also available through Artifact.

ON THE EXAM

The one service here you use once a year and absolutely need when you do.

A start-up in a new AWS account must produce SOC 2 evidence for its first audit. An engineer reads about AWS Audit Manager's SOC 2 framework and tries to enable it. The service cannot be set up in the account.

The team asks what AWS offers instead, and specifically whether AWS Config can produce the same SOC 2 evidence.

What should they be told?

- A Audit Manager closed to new accounts on 30 April 2026; Config conformance packs are the AWS direction, but there is no SOC 2 template
- B Enable Audit Manager in another Region, where it is still available for new accounts
- C Use AWS Artifact to download the SOC 2 report, which satisfies the audit
- D Enable the Security Hub CSPM SOC 2 standard, which replaced the Audit Manager framework

◆ PAUSE AND DECIDE

What should they be told?

- A

 Closed to new accounts; conformance packs are the direction, and there is no SOC 2 template
Correct, and honest about the gap. AWS names SOC 2 and GDPR as the most notable absences from conformance pack templates.
- B

 Try another Region
The restriction is on new accounts, not Regions. A new account cannot set it up anywhere.
- C

 Artifact's SOC 2 report satisfies the audit
The module's core confusion. That report documents AWS's compliance, not the start-up's - it belongs in the audit and does not answer it.
- D

 Security Hub CSPM SOC 2 standard
There is no such standard. Security Hub CSPM covers AWS FSBP, CIS, PCI DSS and NIST 800-53.

THE SIGNAL

The honest answer includes a gap. AWS's recommended path does not fully replace what was lost, and AWS says so.

During a PCI DSS assessment, the auditor asks the company to demonstrate that the physical data centres hosting its cardholder data environment are subject to appropriate physical access controls, and asks for supporting documentation.

The company has no access to AWS data centres and cannot inspect them.

Where does the company get this?

- ☐ A An AWS Config conformance pack for PCI DSS, which covers physical controls
- ☐ B A support case requesting a physical security attestation from AWS
- ☐ C AWS Artifact, which provides AWS's PCI DSS attestation of compliance
- ☐ D Security Hub CSPM's PCI DSS standard findings, exported as evidence

◆ PAUSE AND DECIDE

Where does the company get this?

- A

 A PCI DSS conformance pack
Config rules evaluate AWS resource configuration. There is no Config rule that can inspect a door in a data centre.
- B

 Raise a support case
Unnecessary - the documents are published for self-service download, which is the entire purpose of Artifact.
- C

 AWS Artifact's PCI DSS attestation
Correct. Physical security is AWS's half of the shared responsibility model, and Artifact is how AWS gives you evidence of its own controls.
- D

 Security Hub CSPM PCI DSS findings
Those findings evaluate your resources against PCI-relevant configuration checks. They say nothing about AWS's facilities.

THE SIGNAL

Physical access control is entirely on AWS's side of the line. Every option except Artifact evaluates your own configuration.

A company that has used Audit Manager for three years decides to disable it and move to Config conformance packs. Its compliance team is concerned about losing three years of collected evidence, which auditors may still request.

A platform engineer plans to disable the service from the delegated administrator account this week.

What should the company do first?

- ☐ A Nothing; disabling Audit Manager deletes evidence immediately, so export manually beforehand
- ☐ B Disable from the delegated administrator account as planned, then re-enable to retrieve evidence
- ☐ C Migrate the evidence into a conformance pack, which imports Audit Manager assessments
- ☐ D Enable Evidence Finder first, which exports evidence to a CloudTrail data lake, and disable from the management account

◆ PAUSE AND DECIDE

What should the company do first?

- A

 Disabling deletes evidence immediately
Not so - disabling stops collection and retains existing evidence for two years unless you explicitly choose deletion.
- B

 Disable from the delegated administrator account
Two problems. The delegated administrator lacks permission to disable it for the organisation by default, and re-enabling is a recovery step rather than a plan.
- C

 Migrate evidence into a conformance pack
Invented. Conformance packs evaluate configuration and have no import path for Audit Manager evidence.
- D

 Enable Evidence Finder first; disable from the management account
Correct. AWS names Evidence Finder as the way to keep access - it exports evidence to a CloudTrail data lake that survives disabling.

THE SIGNAL

Two details in one answer: Evidence Finder before disabling, and disable from the management account rather than the delegated admin.

A healthcare group with 90 accounts needs continuous evaluation against HIPAA-relevant technical controls, an organisation-wide compliance score, drill-down to individual non-compliant resources, and automatic remediation where safe.

The group has AWS Config enabled everywhere and is a new AWS customer as of this year.

What should the group deploy?

- ☐ A Audit Manager with the HIPAA framework, delegated across the organisation
- ☐ B A Config conformance pack for HIPAA, deployed across the organisation
- ☐ C Security Hub CSPM with the HIPAA standard enabled through central configuration
- ☐ D AWS Artifact's HIPAA BAA, accepted for every account in the organisation

◆ PAUSE AND DECIDE

What should the group deploy?

A Audit Manager with the HIPAA framework
Would have been the classic answer, and this is a new customer – Audit Manager closed to new accounts on 30 April 2026. It also cannot remediate.

C Security Hub CSPM HIPAA standard
There is no HIPAA standard in Security Hub CSPM – it covers AWS FSBP, CIS, PCI DSS and NIST 800-53.

B A HIPAA conformance pack across the organisation
Correct. Operational Best Practices for HIPAA Security exists as a template, deploys organisation-wide, gives a score with drill-down, and supports remediation.

D The HIPAA BAA from Artifact
Necessary before running HIPAA workloads, and it is a legal agreement rather than a technical control. It evaluates nothing.

THE SIGNAL

'New AWS customer as of this year' rules out Audit Manager, and 'automatic remediation' rules it out a second time.

Six things to carry forward

- ◆ **Artifact is evidence about AWS. Everything else is evidence about you.**
- ◆ **Audit Manager closed to new accounts 30 April 2026** and is in maintenance mode.
- ◆ **Conformance packs are the direction, and not a direct replacement** – no SOC 2 or GDPR template.
- ◆ **Config can remediate. Audit Manager never could.**
- ◆ **Security Hub CSPM covers four standards.** No SOC 2, no HIPAA.
- ◆ **Enable Evidence Finder before disabling Audit Manager**, from the management account.

ON THE EXAM

Next: the shared responsibility model and cost as a security signal.